# Udyam Digital: privacy and security design

This local hackathon prototype uses fictional businesses and synthetic documents. It demonstrates controlled access and minimisation, not production identity verification or legal compliance certification.

**Purpose and consent.** Bundle exploration is anonymous. Separate consents cover Gemini drafting, browser speech, account-bound document extraction/checks and partner contact sharing. Follow-up chat sends a bounded recent conversation and owner-reviewed business facts only after drafting consent; chat remains in the open tab, without browser storage. Authorized reviewers may inspect consented ambiguous evidence. Checkout explicitly simulates payment and activation. Consent versions/timestamps are recorded for retained document journeys.

**Data flow.** PNG/JPEG images are bounded, resized and re-encoded without metadata. Gemini receives pixels, not filenames or registry records. Backend code compares extracted fields to mock registries and masks identifiers. Browser speech may use its provider; transcripts need review before separate Gemini consent. The app records no audio and uses no localStorage, sessionStorage or analytics. An HttpOnly cookie provides account access. Logs omit credentials, conversation/document content and raw provider errors; access logs are disabled.

**Optional messaging.** WhatsApp is disabled by default. Signed events use receiving-account validation and message-ID hashes for deduplication. Separately enabled guided replies require START consent, support Hindi/English, corrections and STOP, and make no Gemini calls. Structured answers are encrypted with a server-only Fernet key; raw incoming text is not persisted. Queued replies contain encrypted recipients/content. Replies target fresh inbound messages only, with no automatic retry after ambiguous sends. STOP deletes local answers and queued payloads; an in-flight/provider-accepted message cannot be recalled. Phone identity never grants private-record access. Document uploads and checkout require web sign-in. Meta's processing/retention is separate.

**Retention and deletion.** Images are never saved. Extracted raw fields expire after 30 minutes or submission; masked records, consent, contact, decisions and orders after 24 hours. Channel answers expire after 30 idle minutes, encrypted outbound payloads after ten minutes, replay hashes after 24 hours. Accounts expire after 30 days without sign-in, sessions after eight hours, aggregate counters after 30 days. Periodic/access/startup cleanup prunes expired rows. Record/account deletion removes applicable local data; withdrawn/resolved follow-up removes contact. Provider records, downloads and backups require separate controls. Restore revokes sessions and clears temporary channel state/queued replies; protect retained encrypted snapshots and their keys separately.

**Access and integrity.** Argon2id protects passwords. Sessions are hashed/revocable, with HttpOnly SameSite cookies. Password changes verify the current password, rotate the current session and revoke all others. Customers can revoke individual/other sessions. Only local operators provision or disable staff; disabling blocks sign-in and revokes all sessions. Ownership and assigned-consent checks protect records. Decisions record actor, reason and evidence revision; only legibility ambiguity can be confirmed after original inspection. Hard failures block checkout. Backend prices, idempotent submission, state checks, bounded requests and transactional schema guards protect integrity.

**Limits.** One local worker; SQLite document/account stores are unencrypted. No MFA, email verification or password recovery. Mock checks do not prove identity, authority or authenticity. Live extraction/voice quality, WhatsApp delivery, container runtime and public deployment remain unverified. Real use needs managed identity, HTTPS/Secure cookies, encrypted storage, shared limits and operational/security/legal review. This is not compliance certification.